Audit dan perbaikan akses produk/katalog, 3 November 2026

Hasil akhir

API katalog dapat dibaca tanpa login. Data produk dan bundle yang memenuhi aturan status aktif dapat dimasukkan ke cart serta diproses menjadi order manual tanpa membedakan asal data, nama toko, atau label simulasi.

Pada database lokal yang diperiksa terdapat 16 listing produk dengan 20 varian aktif, 3 listing bundle, dan 11 kategori. Seluruh 20 varian serta 3 bundle berhasil melewati cart → preview → create order dengan hasil `pending_payment` dan `payment_provider=manual`. Pengujian memakai customer sementara dalam transaksi yang di-rollback; jumlah user, order, cart, dan item cart sebelum/sesudah sama.

Pemeriksaan dilakukan pada aplikasi lokal dan database PostgreSQL audit terpisah. Server production remote belum diuji atau diubah.

Perubahan yang dilakukan

1. **Hapus pembatasan asal data.** Filter `TOKO-SIMULASI-ORDER` pada tambah item cart, preview checkout, dan create order dihapus. Kode atau nama toko tidak lagi menentukan apakah listing boleh dibeli. Akun tetap perlu aktif dan customer hanya dapat mengakses order/alamat miliknya.
2. **Rapikan konfigurasi lokal.** `.env` memiliki dua nilai `ORDER_PROCESSING_MODE`, yaitu `manual` dan `integrated`. Entri ganda dirapikan menjadi satu nilai `manual` sesuai proses pembayaran manual yang dipilih. Data produk, bundle, dan toko tidak direset atau diganti.
3. **Pencarian satu karakter PostgreSQL.** Sebelumnya `/catalog/products?q=a` menghasilkan 500 karena ranking menggunakan alias `search_products` yang belum dijoin. Join sekarang disiapkan untuk semua pencarian tidak kosong.
4. **Pencarian kategori dan lintas field.** Filter tambahan PostgreSQL mengharuskan seluruh frasa cocok pada sebagian field, sehingga menghilangkan hasil yang sebenarnya cocok berdasarkan kategori atau kombinasi nama/deskripsi. Filter tersebut dihapus; pencarian token tetap berlaku dan pemeringkatan tetap dihitung.
5. **Filter harga maksimum saja.** `max_price` sebelumnya selalu dibandingkan dengan `min_price` meskipun minimum tidak dikirim, sehingga respons menjadi 422. Perbandingan kini hanya diterapkan ketika `min_price` disertakan.
6. **Konsistensi bundle pada katalog gabungan.** Katalog gabungan sekarang memakai aturan `purchasable` yang sama dengan katalog bundle. Bundle yang sudah soft-delete, tidak memiliki komponen tersedia, atau berharga nol tidak lagi muncul sebagai penawaran yang dapat dibeli. Pemeriksaan komponen dengan varian hilang juga diperbaiki pada scope model.
7. **Varian yang dihapus.** Perhitungan harga minimum/maksimum, filter harga, pencarian SKU, kategori komponen, dan skor pencarian tidak lagi menghitung data terkait yang sudah soft-delete.
8. **Akses berkas publik.** Storage link lokal disiapkan dengan `php artisan storage:link`. Tidak ada gambar produk baru yang dibuat atau diimpor.

Validasi status tayang, listing aktif, varian aktif, harga, alamat, dan autentikasi pembelian tetap berlaku. Perubahan ini tidak mempublikasikan draft, membuka akun nonaktif, atau mengaktifkan kembali data yang

sudah dihapus.

Verifikasi

Pemeriksaan	Hasil
Suite katalog sebelum perbaikan, SQLite	58 test, 209 assertion, lulus
Suite katalog sebelum perbaikan, PostgreSQL	58 test, 207 assertion, 1 gagal pada pencarian kategori
Reproduksi tambahan sebelum perbaikan, PostgreSQL	11 test, 9 gagal; akses publik dan penolakan produk nonaktif lulus
Suite katalog setelah perbaikan, PostgreSQL	70 test, 260 assertion, seluruhnya lulus
Seluruh suite reguler setelah perbaikan, SQLite	219 test, 1.142 assertion, seluruhnya lulus
HTTP anonim sebelum perbaikan	58 request, 3 respons tidak sesuai: 500 pada pencarian satu huruf dan 422 pada filter maksimum saja di dua endpoint
HTTP anonim setelah perbaikan	58 request, seluruh status respons sesuai
CORS lokal untuk frontend web	GET katalog mengizinkan origin; preflight GET katalog dan POST cart menghasilkan 204 serta mengizinkan header Authorization/Content-Type
Pembelian dari data database lokal	20 varian produk + 3 bundle, seluruhnya berhasil; seluruh transaksi pengujian di-rollback

Pemeriksaan HTTP mencakup daftar katalog gabungan, produk, bundle, kategori; detail seluruh listing/kategori yang ada; pencarian satu karakter; urutan harga; batas harga; pagination; slug tidak ditemukan; serta penolakan query bertipe salah, ukuran halaman berlebih, dan sort tidak valid. Endpoint dibaca tanpa Bearer token, membuktikan akses publik pada deployment lokal.

Uji tambahan sekarang menjadi bagian suite reguler di `tests/Feature/Api/V1/CatalogAccessRegressionTest.php`. Pengujian produk/bundle dengan kode toko lama juga ditambahkan ke `tests/Feature/Api/V1/ManualOrderTest.php`.

Catatan yang masih berlaku

- Seluruh 16 listing produk saat pemeriksaan memiliki galeri kosong pada respons katalog. API tidak gagal, tetapi frontend perlu placeholder sampai gambar diisi melalui panel produk/listing. Pembuatan storage link tidak mengisi data media yang belum ada.
- Harga yang disimpan pada cart tetap digunakan saat order dibuat, sesuai implementasi saat ini. Perubahan kebijakan penguncian harga tidak termasuk pekerjaan ini.

- Pengujian ini bukan uji beban besar atau audit seluruh kemungkinan data produksi. Waktu request pada berkas bukti adalah pengukuran lokal, bukan SLA production.
- Konfigurasi production perlu menggunakan mode order dan `APP_URL` yang sesuai server serta memiliki storage link/permission berkas yang benar.

Bukti

- `http-before-change.json` dan `http-after-change.json`: status serta ringkasan 58 request sebelum/sesudah.
- `purchase-results.json`: hasil cart, preview, dan order untuk setiap varian/bundle beserta jumlah tabel sebelum/sesudah rollback.
- `data-summary.json`: kelengkapan gambar serta jumlah listing produk.
- `cors-results.json`: header akses lintas origin pada aplikasi lokal.
- `catalog-before-postgres.txt`, `catalog-after-postgres.txt`, `full-suite-after.txt`: hasil suite.
- `test-results.json`: ringkasan reproduksi sebelum perbaikan dan suite katalog setelah perbaikan.

Contoh menjalankan suite katalog dengan SQLite tanpa menyentuh database aplikasi:

```
APP_ENV=testing DB_CONNECTION=sqlite DB_DATABASE=:memory: DB_URL= \
CACHE_STORE=array SESSION_DRIVER=array QUEUE_CONNECTION=sync \
MAXCHAT_ENABLED=false MAXCHAT_API_TOKEN= WAREHOUSE_STOCK_ENABLED=false \
SHIPPING_RATE_ENABLED=false WAREHOUSE_DIRECTORY_ENABLED=false
EVERPRO_ENABLED=false \
MIDTRANS_SERVER_KEY= vendor/bin/phpunit --no-progress --filter Catalog
```

Untuk PostgreSQL, gunakan database audit terpisah dan ganti koneksi/database pada perintah. Jangan mengarahkan suite `RefreshDatabase` ke database aplikasi yang berisi data pengguna.